

AI 에이전트 환경에서의 중소기업 내부자 위협과 AI 보안 성숙도 모형

Codex 관찰성 사례, 로그 보존, 시각 교육 및 적응형 정책관리의 한국-불가리아 비교연구

Insider Threats and AI Security Maturity in SME Environments: A Korea-Bulgaria Comparative Study

국제경영 석사과정 제 2 연구계획서 | 지원자: 임채현 (CHAEHEON LIM)

초록

생성형 AI와 에이전트형 도구의 업무 활용이 확대되면서 기업의 내부자 위협은 새로운 양상을 보이고 있다. 특히 정상적인 계정과 업무권한을 가진 사용자가 AI 에이전트에 파일 탐색, 브라우저 조작, 데이터 구조 파악, 반복 검색과 가공을 위임할 경우, 새로운 권한을 획득하지 않더라도 단위시간당 수행 가능한 정보처리의 범위가 크게 늘어날 수 있다. 이러한 변화는 전통적인 접근통제만으로는 충분하지 않으며, 로그 보존, 권한 감사, 직원 교육, 사고보고, 규제와 제품기능의 변경에 대한 조직적 적응을 함께 검토할 필요가 있음을 시사한다. 본 연구는 대기업 수준의 통합 보안체계를 그대로 도입하기 어려운 중소기업을 주요 대상으로 하여, 비용과 인력 제약을 반영한 4단계 AI 보안 성숙도 모형을 제안하고 그 적용 가능성을 한국과 불가리아의 기업환경에서 비교하고자 한다. 연구는 삼성전자의 생성형 AI 정보유출 및 이후 거버넌스 강화 사례, 연구자가 통제하는 합성환경에서의 Codex 관찰성 실험, 한국과 불가리아 중소기업 실무자 인터뷰, 시각적 보안전개도 기반 교육의 기억효과 파일럿, 그리고 법령·공식지침·AI 제품문서의 변경을 내부정책에 연결하는 적응형 정책관리 프로토타입을 결합한다. 최종적으로는 기업 규모와 위험수준에 따라 최소통제에서 고도화된 통제까지 단계적으로 확장할 수 있는 실무모형과, 사고 후 사실관계를 복원할 수 있는 증거준비도 및 정책적응 지연을 측정하는 지표를 제시하는 것을 목표로 한다.

주제어: AI 에이전트, 내부자 위협, 중소기업, AI 보안 성숙도, 로그 보존, 보안교육, 규제 적응, 한국, 불가리아

목차

제 1 장 서론	4
1.1 연구 배경	
1.2 연구 문제	
1.3 연구 필요성	
1.4 연구 목적	
1.5 연구질문 및 예비 분석명제	
1.6 연구 범위 및 연구절차	
1.7 연구의 기대기여	
제 2 장 이론적·제도적 배경	6
2.1 AI 에이전트와 내부자 위협	
2.2 중소기업의 AI 도입과 보안 제약	
2.3 AI 거버넌스와 보안 성숙도	
2.4 관찰가능성, 로그보존 및 증거준비도	
2.5 AI Literacy 와 조직의 보안행동	
2.6 규제변화와 적응형 AI 거버넌스	
2.7 한국과 불가리아의 제도환경	
2.8 이론적 분석틀: Dynamic Capabilities와 Institutional Theory	8
제 3 장 SME AI 보안 성숙도 모형의 개발	9
3.1 SASMM-4 의 설계원칙	
3.2 SASMM-4 의 7 개 평가영역	
3.3 SASMM-4 의 4 단계 성숙도	
3.4 점수체계와 필수 게이트	
3.5 로그보존 및 Evidence Readiness	
3.6 교육·행동 성숙도	
3.7 정책적응 성숙도	
3.8 SASMM-4 상세 통제 매트릭스	
3.9 SME 단계별 투자우선순위	
제 4 장 연구설계 및 방법론	13
4.1 연구의 전체 설계	
4.2 Study 1 - 문헌·규제·표준 비교분석	
4.3 Study 2 - 삼성전자 종단 사례연구	
4.4 Study 3 - Codex 합성환경 관찰가능성 실험	
4.5 Study 4 - 한국·불가리아 SME 인터뷰 및 설문	
4.6 Study 5 - AI 보안교육 파일럿	
4.7 Study 6 - A-REG 프로토타입	
4.8 전문가 검증	
4.9 연구윤리 및 데이터관리	
4.10 연구 수행가능성·범위통제·추진일정	

제 5 장 분석결과의 구성 및 검증계획	18
5.1 문헌·규제·표준 매핑	
5.2 삼성전자 사례분석	
5.3 Codex 관찰가능성 실험	
5.4 한국·불가리아 SME 비교	
5.5 시각적 보안교육 파일럿	
5.6 A-REG 프로토타입 평가	
5.7 전문가 검증 및 SASMM-4 최종모형	
제 6 장 종합논의	19
6.1 정상권한 증폭과 Agentic Insider Risk	
6.2 SME AI 보안 성숙도의 핵심 메커니즘	
6.3 관찰가능성과 Evidence Readiness	
6.4 사람과 교육의 역할	
6.5 Adaptive Policy Governance 의 역할	
6.6 한국-불가리아 비교	
6.7 학술적 의의	
6.8 기업경영 및 실무적 의의	
6.9 정책적 의의	
제 7 장 결론	21
7.1 연구계획의 요약	
7.2 연구질문에 대한 통합적 답변 구조	
7.3 연구의 한계	
7.4 후속 연구	
7.5 장기 연구방향	
참고문헌	22

연구구조 요약

문제 제기 -> 이론·제도적 근거 -> 이론적 분석틀 -> SASMM-4 개발 -> 복수 방법을 통한 검증 -> 분석결과 통합 -> 종합논의 -> 결론

제1장 서론

1.1 연구 배경

기업의 생성형 AI 활용은 단순한 질의·응답 도구를 넘어, 파일 탐색, 브라우저 조작, 데이터 구조 파악, 반복 검색, 요약·변환, 코드와 업무흐름 자동화를 연결하는 에이전트형 사용으로 이동하고 있다. 이 변화는 생산성을 높이는 동시에 내부자 위협의 전제를 바꾼다. 특히 정상적인 계정과 업무권한을 가진 사용자가 AI 에이전트에 복수 단계의 정보처리를 위임하면, 새로운 권한을 획득하지 않더라도 단위시간당 접근·집계·가공 가능한 정보의 범위가 크게 확대될 수 있다. 본 연구는 이러한 현상을 AI 에이전트 시대의 내부자 위협으로 다룬다.

기존 연구계획의 중심축은 AI 에이전트 기반 정보역량이 중소기업의 국제화와 시장진입 준비도를 어떻게 개선할 수 있는가에 있다. 본 제 2 연구계획은 그 방향을 대체하지 않고, 동일한 AI 역량이 기업에서 지속가능하게 활용되기 위한 보안·거버넌스의 경계조건을 독립적으로 분석한다. 즉 연구축 I 이 AI 활용의 가치와 국제화 역량을 설명한다면, 연구축 II 는 그 역량을 신뢰할 수 있게 만드는 내부통제, 교육, 증거보존, 규제적응 능력을 설명한다.

1.2 연구 문제

전통적인 내부자 위협 관리는 주로 “누가 어떤 시스템에 접근할 수 있는가”라는 인증과 권한부여에 초점을 두어 왔다. 그러나 에이전트형 AI 는 이미 허용된 권한을 빠르게 반복·확장해 사용할 수 있으므로, 정상 로그인과 정상 권한만으로 행위의 위험성을 판단하기 어려워진다. 따라서 핵심 문제는 권한의 존재 자체보다, 그 권한이 자동화와 결합될 때 정보처리 능력이 얼마나 증폭되고 그 과정을 조직이 어느 지점에서 관찰·감사·차단할 수 있는가이다.

중소기업에서는 이 문제가 더 복잡하다. 대기업은 SIEM, EDR, DLP, PAM, 전담 SOC, 장기 데이터레이크와 법무·보안·감사조직을 결합할 수 있지만, 중소기업은 예산·인력·레거시 시스템 제약으로 동일한 수준의 통제를 일시에 구축하기 어렵다. 따라서 대기업 통제를 단순 축소하는 방식이 아니라, 비용 대비 위험감소 효과가 큰 최소통제부터 단계적으로 확장하는 별도의 성숙도 모형이 필요하다.

1.3 연구 필요성

AI 에이전트 시대의 중소기업 보안은 기술통제만으로 충분하지 않다. 최소권한과 데이터 분류 같은 예방통제, 로그 장기보존과 감사 같은 관찰통제, 직원과 권한자의 반복교육, 사고보고와 증거보존 절차, 그리고 법령·공식지침·AI 제품기능 변경을 내부정책에 반영하는 적응능력이 하나의 체계로 연결되어야 한다. 특히 보안교육은 “교육을 실시했다”는 활동지표보다, 직원이 실제 상황에서 위험단계와 보고시점을 기억하고 행동할 수 있는지를 기준으로 평가할 필요가 있다.

한국과 불가리아의 비교는 동일한 중소기업 보안모형이 서로 다른 디지털 성숙도와 규제환경에서 어떻게 구현되는지를 살펴볼 수 있다는 점에서 의미가 있다. 비교의 목적은 양국을 서열화하는 것이 아니라, 공통된 SME 자원제약과 국가별 제도·지원체계의 차이가 통제 도입순서, 교육방식, 로그보존, 정책적응에 어떠한 차이를 만드는지 분석하는 데 있다.

1.4 연구 목적

본 연구의 목적은 AI 에이전트가 정상 내부권한을 가진 사용자의 정보처리 능력을 확대하는 상황에서, 자원이 제한된 중소기업이 내부자 위협을 예방·관찰·감사·교육·대응할 수 있는 4 단계 AI 보안 성숙도 모형(SME Agentic Security Maturity Model, SASMM-4)을 개발하고 검증하는 것이다. 연구 구성요소의 위계는 명확히 구분한다. 핵심 산출물은 SASMM-4이며, Agentic Privilege Amplification(APA)은 정상권한과 에이전트 자동화의 결합을 설명하는 분석 메커니즘이다. Evidence Readiness Index(ERI)와 Policy Change-to-Control Latency(PCCL)는 각각 증거준비도와 정책·통제 적응속도를 평가하는 운영지표로 사용하고, Visual Security Recall(VSR)은 시각교육의 기억·판단 효과를 측정하는 보조 변수로 사용한다. 이를 통해 새로운 용어 자체보다 SME의 AI 거버넌스 성숙도와 의사결정에 초점을 둔다.

1.5 연구질문 및 예비 분석명제

1.5.1 Main RQ1 - AI 에이전트는 정상 내부권한 하에서 SME 의 내부자 위협을 어떻게 변화시키는가?

RQ1-1. 정상권한의 자동화는 정보접근·집계·가공·이동능력에 어떠한 변화를 발생시키는가?

RQ1-2. AI·DB·Endpoint·Network 계층의 로그 범위와 보존조건은 사고 후 증거준비도(ERI)에 어떠한 영향을 미치는가?

1.5.2 Main RQ2 - SME 의 자원제약을 고려한 AI 보안 성숙도 모형은 어떻게 구성되어야 하는가?

RQ2-1. 어떠한 통제가 자원 제약에도 불구하고 우선적으로 확보해야 할 최소 필수 게이트로 요구되는가?

RQ2-2. 교육·행동 통제와 시각적 보안전개도는 성숙도에 어떻게 포함되어야 하는가?

RQ2-3. 규제·제품변경에 대한 조직의 적응능력과 A-REG 프로세스는 어떻게 포함되어야 하는가?

1.5.3 Main RQ3 - 한국과 불가리아의 기업·제도환경은 SASMM-4 의 적용방식에 어떠한 차이를 발생시키는가?

Main RQ3 는 동일한 모형이 한국과 불가리아에서 어떻게 다르게 구현되는지를 비교하되, 불가리아의 상위 제도환경인 EU 규범을 별도 맥락층으로 분석한다. 교육·감사·보존·정책적응의 우선순위와 구현방식 차이에 초점을 둔다.

1.5.4 예비 분석명제

- P1. 내부자 위협의 증가는 새로운 권한 획득보다 정상권한과 에이전트 자동화의 결합에서 크게 나타나며, 자동화 강도와 권한 민감도가 높을수록 Agentic Privilege Amplification(APA)이 커질 것이다.
- P2. 단일 로그보다 에이전트·DB·Endpoint·Network 의 다계층 로그와 충분한 보존기간의 결합이 ERI 를 높일 것이다.
- P3. 중소기업의 초기 단계에서는 고가 솔루션보다 최소권한, 퇴직권한 회수, 중요로그 아카이빙, 승인된 AI, 반복교육, 단일 신고체계의 조합이 비용 대비 위험감소 효과가 클 것이다.
- P4. 시각적 보안전개도와 역할별 행동규칙을 활용한 마이크로러닝은 텍스트 규정 중심 교육보다 위험식별과 지연기억을 개선할 가능성이 있다.
- P5. 공식 출처 변경탐지와 인간 승인을 결합한 A-REG 프로세스는 자동 법률판단 없이도 PCCL 을 단축하고 정책 변경이력을 더 명확히 할 수 있다.

1.6 연구 범위 및 연구절차

연구는 탐색적 순차 논리를 따르는 다단계 혼합방법 설계(multiphase mixed-methods design with exploratory sequential logic)를 기본으로 한다. 문헌·규제·표준 비교분석을 통해 SASMM-4 의 초안을 구성한 뒤, 삼성전자 공개사례의 중단 분석, 연구자가 소유·통제하는 합성환경에서의 Codex 관찰가능성 실험, 한국·불가리아 SME 인터뷰와 선택적 설문, 시각교육 파일럿, A-REG 프로토타입 평가, 전문가 검증을 순차적으로 결합한다. 실제 기업의 기밀 DB나 제3자 시스템을 대상으로 하는 공격·우회 실험은 연구범위에서 제외한다.

분석단위는 특정 AI 제품의 성능 그 자체가 아니라, 기업이 AI 를 안전하게 사용하기 위해 구축하는 반복 가능한 조직 능력이다. 따라서 제품기능이 연구기간 중 변경되더라도 권한, 데이터, 관찰성, 교육, 사고대응, 정책적응이라는 상위 통제 원칙이 유지되도록 설계한다.

1.7 연구의 기대기여

본 연구는 내부자 위협을 “악의적인 직원”이라는 행위자 특성만으로 설명하기보다 정상권한의 에이전트 증폭, 증거준비도, 교육기억, 정책적응지연을 함께 고려하는 조직 거버넌스 문제로 확장한다. 실무적으로는 중소기업이 지금 가진 자원에서 시작할 수 있는 최소통제와 성장 단계별 투자순서를 제시하고, 학술적으로는 AI 거버넌스·사이버보안 성숙도·인적행동·국제제도 비교를 국제경영의 디지털 전환 연구와 연결하는 것을 목표로 한다.

제 2 장 이론적·제도적 배경

2.1 AI 에이전트와 내부자 위협

2.1.1 전통적 내부자 위협과 정상권한의 문제

전통적인 내부자 위협에서는 권한 오남용, 기밀정보 반출, 특권계정 관리, 퇴직자 권한회수 등이 핵심 통제대상이다. 에이전트형 AI가 추가되면 이러한 통제의 중요성은 사라지지 않고 오히려 강화된다. AI가 새로운 권한을 창조하지 않더라도 사용자가 가진 정상 권한을 활용해 복수 단계의 업무를 빠르게 연결할 수 있기 때문이다.

2.1.2 AI 에이전트의 권한 승계와 자동화

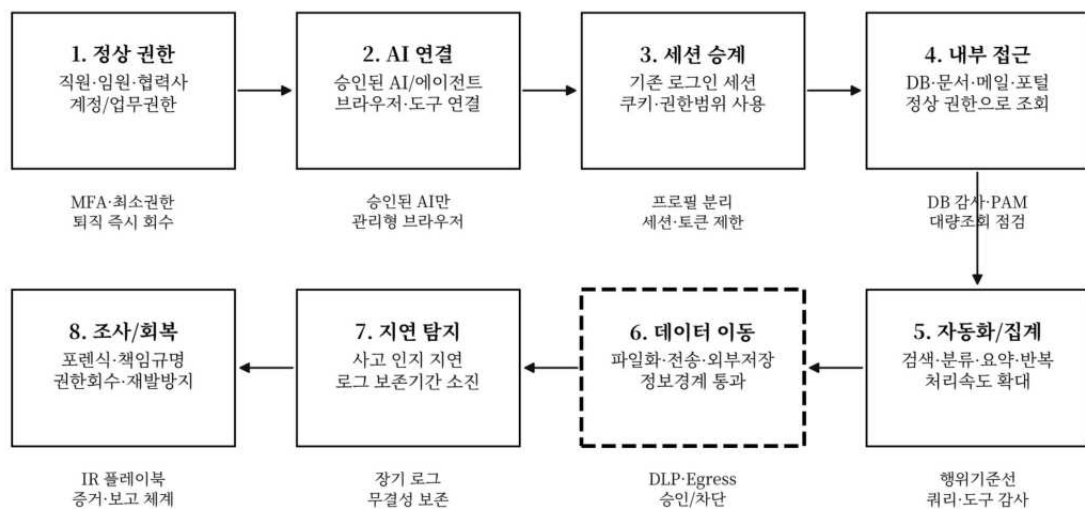
로그인된 브라우저 세션, 로컬 파일, 업무용 도구, 데이터베이스 접근권한이 AI 에이전트의 작업환경에 연결되면 실질적인 접근범위는 해당 사용자 계정과 세션에 부여된 권한에 의해 결정된다. 따라서 기업은 사람의 권한과 그 사람이 에이전트에 위임할 수 있는 권한을 동일한 보안경계 안에서 평가할 필요가 있다.

2.1.3 정상권한 증폭과 Agentic Insider Risk

본 연구는 동일한 권한 집합 아래에서 자동화가 단위시간당 정보접근·집계·가공 범위를 확대하는 현상을 Agentic Privilege Amplification(APA)으로 조작적으로 정의한다. APA는 곧바로 범죄나 침해를 의미하는 개념이 아니라, 정상 권한이 에이전트 자동화와 결합될 때 조직이 고려해야 하는 잠재적 위험증폭 메커니즘이다.

2.1.4 AI 에이전트 기반 정보사고의 단계별 전개

AI 에이전트 기반 정보사고의 단계별 전개와 통제 지점



핵심 관점: 정상 권한 자체보다, 정상 권한이 에이전트 자동화와 결합될 때 정보처리 범위가 얼마나 확대되는지와 이를 어느 지점에서 관찰·통제할 수 있는지가 중요하다.

그림 1. AI 에이전트 기반 정보사고의 단계별 전개와 통제 지점. 굵은 점선은 데이터 이동 경계에서 유출위험이 집중되는 구간을 표시한다.

2.2 중소기업의 AI 도입과 보안 제약

중소기업은 AI 도입으로 정보검색·번역·분석·업무자동화의 비용을 낮출 수 있지만, 동시에 전담 보안인력과 고가 보안도구가 부족한 상태에서 새로운 권한위임 경로를 관리해야 한다. ENISA는 SME 보안의 대표적 제약으로 예산과 사이버 역량 부족을 지적하며 [2], OECD의 SME AI 논의 역시 도입의 확대와 함께 전략적·안전한 통합 역량의 격차를 중요한 과제로 다룬다 [1].

따라서 중소기업용 보안모형은 “대기업의 통제를 얼마나 많이 보유했는가”보다 “현재 위협에 비해 반드시 필요한 최소선을 확보했는가”와 “성장에 따라 다음 통제로 확장할 수 있는가”를 중심으로 설계할 필요가 있다.

2.3 AI 거버넌스와 보안 성숙도

NIST AI RMF와 GenAI Profile은 AI 위협을 전 생애주기에서 식별·측정·관리·거버넌스할 필요성을 강조하며 [16], NIST CSF 2.0은 조직의 사이버보안 성숙도를 거버넌스와 운영통제로 연결한다 [17]. 그러나 기존 프레임워크를 그대로 적용하면 SME의 비용·인력 제약, 에이전트의 권한승계, 직원교육의 기억효과, 로그보존기간, 제품기능 변경이라는 현실적 문제를 충분히 구체화하기 어렵다. 본 연구는 이 간극을 SASMM-4의 설계문제로 다룬다.

2.4 관찰가능성, 로그보존 및 증거준비도

에이전트형 업무에서는 사고의 예방뿐 아니라 사고 후 무엇이 일어났는지를 복원할 수 있는 관찰가능성이 중요하다. Codex의 공식 고급설정 문서는 OpenTelemetry(OTel) 로그 내보내기가 기본적으로 비활성화되어 있으며 exporter의 기본값이 none이고 사용자 프롬프트 내용은 별도 설정 없이도 내보내지 않도록 설명한다 [14]. 따라서 조직이 사전에 외부 수집을 구성하지 않으면 에이전트 수준의 작업맥락이 중앙 SIEM에 자동 축적된다고 가정할 수 없다.

Enterprise/Edu의 Compliance Logs Platform은 감사이벤트를 제공하지만 기본 보존기간은 30일이며, 더 긴 보존이 필요하면 조직이 로그를 지속적으로 내려받아 자체 정책에 따라 보관해야 한다 [15]. 이러한 공급자측 보존과 기업 자체 로그보존의 차이는 “사고가 발생했는가”와 별개로 “사고를 나중에 입증·재구성할 수 있는가”에 영향을 준다. 본 연구는 이를 ERI라는 운영지표로 측정한다.

2.5 AI Literacy와 조직의 보안행동

AI 보안은 보안담당자만의 전문영역으로 남기 어렵다. EU AI Act의 AI literacy 체계는 AI 시스템 제공자와 배포자 직원과 그들을 대신해 AI 시스템을 사용하는 사람의 AI literacy를 지원하도록 요구하며, 조직의 사용맥락과 기술수준을 고려한 조치를 강조한다 [7][18]. 따라서 직원·권한자·관리자·임원이 동일한 위험경로를 이해하고 자신의 역할에 맞는 금지행위, 승인절차, 보고시점을 기억하도록 만드는 교육은 조직거버넌스의 일부로 볼 수 있다.

2.6 규제변화와 적응형 AI 거버넌스

AI 기술과 제품기능의 변화주기가 법·가이드·사내정책의 개정주기보다 빠르면 통제의 기준이 실제 시스템과 불일치하는 Control Drift가 발생할 수 있다. 본 연구는 법이 기술을 선행한다고 가정하기보다, 공식 변경이 발표된 시점부터 기업의 정책·통제·교육자료에 반영될 때까지 걸린 시간을 PCCL로 측정하고 이를 줄이는 조직능력을 Adaptive Policy Governance로 다룬다.

2.7 한국과 불가리아의 제도환경

2.7.1 한국의 AI·개인정보·보안 환경

한국에서는 AI 기본법 체계, 개인정보보호위원회의 생성형 AI 관련 개인정보 안내, KISA의 AI 보안 가이드 등이 기업의 안전한 AI 활용과 내부통제 논의를 강화하고 있다 [8][9][10]. 본 연구는 법률의 최종 해석보다 이러한 공식 규범이 실제 기업정책과 교육·로그·권한관리로 얼마나 신속히 전환되는지를 분석한다.

2.7.2 EU AI Act와 AI Literacy

불가리아는 EU 회원국으로서 EU AI Act와 EU 차원의 AI literacy·사이버보안 정책환경 안에서 기업의 AI 도입을 추진한다. 이는 교육, 책임, 문서화, 위험관리 등 조직적 통제를 국제경영의 실제 운영환경과 연결해 관찰할 수 있는 비교 맥락을 제공한다.

2.7.3 불가리아 SME 디지털 환경

유럽연합 집행위원회의 2026 Digital Decade 국가보고서는 불가리아 SME의 디지털화가 EU에서 낮은 수준에 머물고 AI·클라우드·데이터 분석 도입이 제한적이며, SME의 사이버보안 성숙도가 불균등하다고 평가한다 [3]. Eurostat

의 2026 디지털화 자료에서는 2025 년 기본 디지털 집약도에 도달한 SME 비율이 불가리아 38%, EU SME 71%, EU 대기업 96%로 나타난다 [6].

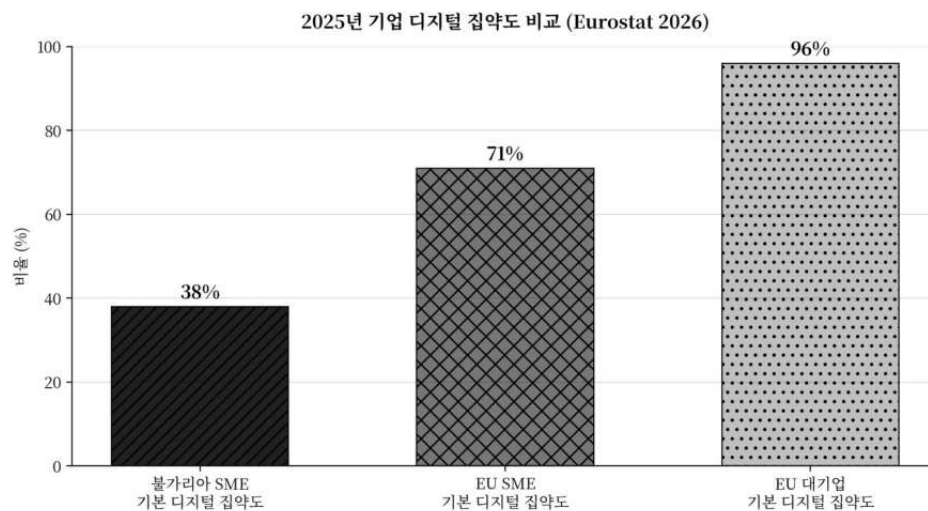


그림 2. 2025 년 기업 디지털 집약도 비교. 불가리아 SME와 EU SME·대기업 사이의 격차는 AI 활용 확대와 보안통제 역량 사이의 시차를 비교하기 위한 제도적 배경을 제공한다 [6].

2.7.4 한국-불가리아 비교의 분석적 의미

축	한국	불가리아 (상위 제도환경: EU)
규제환경	AI 기본법 시행체계, 개인정보보호·보안 지침	EU AI Act, GDPR, EU 사이버 규범, AI literacy
기업환경	높은 디지털 인프라와 빠른 AI 도입	SME 디지털 집약도와 사이버성숙도 격차
주요 관찰점	빠른 도입에 따른 Control Drift와 내부통제	자원제약 하의 최소통제·교육·지원체계
공통문제	전담 보안인력이 부족한 SME, 레거시 시스템, Shadow AI, 권한자 위협	동일한 구조적 문제를 다른 제도환경에서 비교

2.8 이론적 분석틀: Dynamic Capabilities와 Institutional Theory

본 연구는 SASMM-4를 단순한 보안 체크리스트가 아니라 기술·위험·규제 변화에 대응해 통제를 계속 조정하는 조직역량의 성숙도 모형으로 해석한다. Dynamic Capabilities 관점에서 sensing은 에이전트 위협, 로그 사각지대, 규제·제품변경을 탐지하는 능력(OBS·ADP), seizing은 제한된 자원 아래 통제 우선순위와 투자결정을 선택하는 능력(GOV·IAM·DATA), reconfiguring은 정책·권한·교육·사고대응 체계를 재구성하는 능력(HUM·IR·ADP)으로 연결할 수 있다 [19].

Institutional Theory는 동일한 성숙도 모형이 국가별 제도환경에서 왜 다르게 구현되는지를 설명하는 보조 렌즈로 사용한다. 한국의 빠른 디지털 도입과 국내 규범환경, 불가리아에 적용되는 EU AI Act·AI literacy·GDPR 등은 기업에 서로 다른 강도의 제도적 압력과 정당성 요구를 형성할 수 있다 [20]. 따라서 한국-불가리아 비교는 국가의 우열을 평가하는 것이 아니라, 제도적 압력과 SME의 동적 대응역량이 통제의 도입순서·교육·로그보존·정책적응에 어떻게 상호작용하는지를 분석한다.

통합적으로 SASMM-4는 “변화를 감지하고(sense), 우선순위를 결정하며(seize), 통제를 재구성하는(reconfigure) secure governance capability”의 단계적 성숙도를 나타내고, EU를 포함한 국가별 제도환경은 그 구현방식을 조건화하는 맥락층으로 취급한다.

제 3 장 SME AI 보안 성숙도 모형의 개발

3.1 SASMM-4 의 설계원칙

- SME 적용성: 대기업 전담조직을 전제로 하지 않고 소규모 조직에서도 시작 가능한 통제를 우선한다.
- 비용효율성: 구매 제품 수가 아니라 위험감소 대비 비용과 관리가능성을 기준으로 단계화한다.
- 단계적 확장성: Level 1 의 최소선에서 Level 4 의 고도화된 통제로 연속적으로 확장할 수 있게 한다.
- 기술통제와 조직통제의 통합: 권한·데이터·로그뿐 아니라 교육·보고·규제적응을 동일한 성숙도 체계에 포함한다.
- 증거와 책임의 보존: 사고예방만이 아니라 사후 사실관계 재구성과 책임있는 의사결정을 평가한다.

3.2 SASMM-4 의 7 개 평가영역

코드	영역	핵심 평가내용
GOV	거버넌스	AI 사용정책, 승인도구, 책임자, 경영진 보고, 공급자 위험관리
IAM	권한·신원	MFA, 최소권한, 특권계정 분리, JIT/PAM, 퇴직·이동 권한회수
DATA	데이터	분류, AI 입력금지 데이터, DLP, 비식별, 데이터 이동경계
OBS	관찰·로그	AI telemetry, DB audit, Endpoint/Network 로그, 장기보존, 무결성
HUM	교육·행동	전 직원 AI 보안교육, 권한자 심화교육, 시각전개도, 신고훈련
IR	사고대응	보고 채널, 증거보존, 권한회수, 법무·개인정보 대응, 복구
ADP	규제적응	법·지침·제품변경 모니터링, 영향평가, 정책개정 SLA, 승인 이력

3.3 SASMM-4 의 4 단계 성숙도

SASMM-4 | SME Agentic Security Maturity Model (4단계)

LEVEL 1	MINIMUM 최소 필수수준
대상: 모든 조직	AI 사용정책 · MFA · 최소권한 · 퇴직회수 · 사고보고 · 최소 로그보존 비용: 매우 낮음
LEVEL 2	SME BASELINE 중소기업 권고
대상: 일반 중소기업	중앙 로그 아카이브 · 정기 권한감사 · 관리형 AI · 시각교육 · 중요 DB 접근감사 비용: 낮음~중간
LEVEL 3	ADVANCED 고위험/성장기업
대상: 중견·고위험 산업	SIEM/EDR/DLP · PAM/JIT · Agent Identity · 이상행동 탐지 · 정기 훈련/레드팀 비용: 중간~높음
LEVEL 4	ENTERPRISE/CRITICAL 대기업·핵심산업
대상: 대기업·금융·핵심정보	실시간 SOC · 불변 로그 · 전사 AI 거버넌스 · 지속통제 · 공급망·법규 자동추적 · Red Team 비용: 높음

설계 원칙: 점수만 높다고 상위 단계가 되는 것이 아니라, MFA·퇴직자 권한회수·사고보고·로그 무결성 등 “필수 게이트”가 빠지면 상위 단계 진입을 제한한다.

그림 3. SME Agentic Security Maturity Model(SASMM-4). 단계는 조직의 위험수준과 비용·인력 제약을 함께 고려한다.

단계	목표	대표 통제
Level 1 Minimum	모든 기업이 지켜야 할 최소선	정책·MFA·최소권한·퇴직회수·핵심 로그·신고채널·기본교육
Level 2 SME Baseline	일반 중소기업의 권고 기준	중앙 로그아카이브·정기 권한검토·관리형 AI/브라우저·중요 DB 감사·분기교육
Level 3 Advanced	중견·고위험 조직	SIEM/EDR/DLP/PAM, 역할별 훈련, 이상행동 탐지, 자동 Diff·통제매핑
Level 4 Enterprise/Critical	대기업·핵심정보·규제산업	SOC·지속통제·Agent Identity·장기 감사 증적·독립 assurance

3.4 점수체계와 필수 게이트

SASMM-4는 단순 합산점수만으로 성숙도를 판정하지 않는다. 중요한 통제가 누락되어도 다른 항목의 높은 점수로 상쇄되는 문제를 막기 위해 “영역점수 + Mandatory Gate”의 이중구조를 사용한다. 예비 필수 게이트는 승인된 AI 사용 정책, MFA, 퇴직·계약종료 권한 즉시 회수, 중요사고 단일 신고채널, 최소 로그보존, AI 입력금지 데이터의 명시이다. 하나라도 미충족하면 상위단계 진입을 제한하는 방식으로 검증한다.

예비 점수체계. AI Security Maturity Score = $\Sigma(\text{영역별 가중치} \times \text{영역점수})$. 초기 가중치는 GOV 15, IAM 15, DATA 15, OBS 20, HUM 15, IR 10, ADP 10 으로 설정하고 전문가 검증과 파일럿 결과를 통해 조정한다. 점수는 참고값이며 Mandatory Gate 를 대체하지 않는다.

3.5 로그보존 및 Evidence Readiness

단계	연구상 운영 목표치	설계 원칙
L1 Minimum	최소 180 일	보안 메타데이터 중심, 목적 제한·개인정보 최소화, 저비용 중앙 아카이브

단계	연구상 운영 목표치	설계 원칙
L2 SME Baseline	365 일	AI·인증·중요 DB·Endpoint 핵심로그 중 양보존, 정기 점검
L3 Advanced	2 년 내외	SIEM/EDR/PAM 연계, 감사 추적성, 중요 사건 WORM 고려
L4 Enterprise/Critical	위험·법규 기반 3 년+ 또는 별도 기준	산업규정·소송보존·개인정보 원칙을 함께 고려한 차등보존

위 기간은 법적 의무가 아니라 연구에서 검증할 운영상 목표치이다. 보존기간은 사건탐지 지연과 조사 필요성을 충분히 포괄하면서도 개인정보 보호의 목적제한·최소보유 원칙과 함께 설계되어야 한다.

ERI 구성요소	측정 취지
증거범위	AI·DB·Endpoint·Network·인증 중 확인 가능한 중요계층의 비율
보존충족	사건발견 지연 대비 로그가 남아 있는 기간의 충족도
귀속성	사용자·기기·세션·에이전트 활동의 연결 가능성
무결성	append-only/WORM 등 변조방지와 감사 신뢰성
조사효율	사건 재구성에 필요한 시간과 수작업 부담

3.6 교육·행동 성숙도

교육영역은 “연 1 회 수료”를 성숙도로 보지 않는다. Level 1에서는 최소한의 금지정보와 신고절차를 기억하게 하고, Level 2에서는 분기 마이크로러닝과 공통 시각전개도를 적용하며, Level 3 이상에서는 권한자·관리자·임원별 시나리오 훈련과 사고대응 연습으로 확장한다. 성과는 위험식별, 보고시점, 지연기억, 역할별 판단정확도로 측정한다.

대상	핵심 질문	교육/성과 지표
직원	무엇을 AI에 넣으면 안 되는가? 언제 바로 신고해야 하는가?	금지정보 식별·위험단계 기억·신고의도
권한자/개발자	어떤 세션·DB·도구권한을 에이전트에 위임할 수 있는가?	특권행위 인지·승인절차 준수
관리자/감사	어떤 로그를 얼마 동안 남겨야 조사 가능한가?	권한검토·보존완결성·증거준비도
임원	어느 통제가 가장 싸고 큰 위험을 줄이는가?	예산배분·잔여위험 판단

3.7 정책적응 성숙도

ADP 영역은 규제와 제품기능 변화에 대한 조직의 반응속도를 평가한다. Level 1에서는 최소 월 1회 공식 출처 확인과 정책 버전기록을 요구하고, Level 2에서는 A-REG 알림과 분기 정책검토, Level 3에서는 자동 Diff와 통제 영향매핑, Level 4에서는 지속 모니터링과 경영진 리스크 대시보드로 확장한다. 자동화는 변경점 탐지와 초안 제시에 한정하고 법적 판단과 정책 발효는 사람의 승인을 거친다.

3.8 SASMM-4 상세 통제 매트릭스

영역	L1 Minimum	L2 SME Baseline	L3 Advanced	L4 Enterprise/Critical
AI 정책	승인/금지 원칙 문서화	승인도구·입력등급·역할별 규정	Policy-as-Code·예외승인	전사 AI governance + 자동 지속통제
권한	MFA·최소권한·퇴직회수	분기 권한검토·브라우저 분리	PAM/JIT·Agent Identity	연속 권한평가·고위험 세션 실시간 통제
데이터	금지정보 목록·기본 분류	중요정보 라벨·승인된 저장/전송	DLP·세분화·암호화	전사 데이터 거버넌스·동적 정책집행
로그	핵심 로그 180 일 목표	중앙 1년 아카이브	SIEM/EDR/PAM 2년 내외	WORM/데이터레이크·산업별 장기보존
교육	입사/연 1 회 + 짧은 사례	분기 마이크로러닝 + 시각 전개도	역할별 시뮬레이션·훈련	지속학습·레드팀·경영진 tabletop
감사	월/분기 체크리스트	권한자·AI 사용 정기감사	UEBA/이상행동·전문감사	SOC·실시간 분석·독립 assurance
사고대응	단일 신고채널·증거보존	AI 사고 플레이북	기술·법무·PR 통합 대응	글로벌 규제·공급망·위기 관리 연계
정책적응	월 1 회 공식출처 확인	A-REG 알림·분기 정책검토	자동 Diff + 통제매핑	지속 모니터링 + 이사회 리스크 대시보드

3.8.1 Level 1 최소 필수 통제의 실무 예시

승인된 AI 서비스와 업무계정만 사용하고 소비자형 개인계정 사용범위를 문서화한다.

개인정보·영업비밀·소스코드·미공개 재무자료 등 AI 입력금지 데이터를 구체적인 예시와 함께 정한다.

MFA와 최소권한을 기본값으로 하고 특권계정은 일상용 계정과 분리한다.

퇴사·계약종료·부서이동 시 AI·메일·DB·VPN·클라우드 권한을 하나의 체크리스트로 회수한다.

중요 DB·인증·VPN·AI 사용기록을 중앙 아카이브로 수집하고 보존정책을 명시한다.

브라우저 AI 에이전트는 관리형 프로필을 사용하고 관리자·핵심시스템 세션과 분리한다.

대량 조회·다운로드·새 외부 도메인 연결 등 이상행위를 정기적으로 점검한다.

전 직원에게 짧은 반복형 AI 보안교육을 시행하고 권한자는 심화교육을 받는다.

사고를 즉시 보고할 단일 연락채널과 증거보존 절차를 만든다.

법·가이드·제품기능 변경을 정기 확인하고 정책 버전과 변경이력을 남긴다.

3.9 SME 단계별 투자우선순위

- 1 순위(거의 무료): 사용정책, 금지정보 예시, MFA, 퇴직권한 회수, 단일 신고채널, 짧은 반복교육.
- 2 순위(저비용): 중요 로그 중앙 아카이브, 관리형 브라우저·업무용 AI 계정, 중요 DB 감사, 정기 권한점검.
- 3 순위(선택적 기술투자): EDR 또는 DLP 부터 위험이 큰 데이터흐름에 집중 적용한다.
- 4 순위(성장·고위험): PAM/JIT, SIEM, UEBA, Agent Identity, 지속통제, 독립감사로 확장한다.

이 투자순서는 보안제품 구매액이 아니라 위험감소 대비 비용과 운영가능성을 기준으로 한다. 특히 로그보존은 고가 SIEM 없이도 저비용 중앙 저장소와 수명주기 정책으로 시작할 수 있으므로 SME의 초기 투자항목으로 검증할 가치가 있다.

제 4 장 연구설계 및 방법론

4.1 연구의 전체 설계

본 연구는 탐색적 순차 논리를 따르는 다단계 혼합방법 설계(multiphase mixed-methods design with exploratory sequential logic)를 적용한다. 문헌·규제·표준 분석 -> 공개사례 중단 분석 -> 합성환경 통제실험 -> SME 현장 인터뷰·설문 -> 교육 파일럿 -> A-REG 프로토타입 -> 전문가 검증 순으로 진행하며, 각 Study 는 서로 독립된 별도 연구가 아니라 SASMM-4 의 내용타당도·관찰가능성·현장적용성·행동효과·정책적응성을 서로 다른 자료로 검증한다.

구성	방법	SASMM-4 에서 검증하는 요소
Study 1	문헌·규제·표준 비교	SASMM-4 통제영역과 내용타당도
Study 2	삼성전자 2023-2026 중단 사례	사고-통제-교육-거버넌스-관리형 재도입의 성숙도 이동
Study 3	Codex 합성환경 관찰가능성 실험	로그범위·보존·귀속성이 ERI 에 미치는 영향
Study 4	한국·불가리아 SME 인터뷰/설문	자원제약과 국가맥락에 따른 적용가능성
Study 5	AI 보안교육 파일럿	시각전개도·마이크로러닝의 VSR 효과
Study 6	A-REG 프로토타입	정책변경 탐지·매핑·승인 프로세스의 PCCL 평가

4.2 Study 1 - 문헌·규제·표준 비교분석

NIST AI RMF/GenAI Profile, NIST CSF 2.0, ENISA SME cybersecurity, OECD D4SME, EU AI Act/AI literacy, 한국 AI 기본법·PIPC·KISA 지침을 매핑하여 공통 통제영역과 SME 특화요건을 도출한다 [1][2][7][8][9][10][16][17][18]. 분석단위는 조항의 개수보다 기업이 실제 수행해야 하는 조직행위(교육, 기록, 권한, 검토, 보고, 승인)로 설정한다.

4.3 Study 2 - 삼성전자 중단 사례연구

4.3.1 사례선정 근거

삼성전자 사례는 생성형 AI 사용 중 민감정보 입력 위험이 공개적으로 알려진 2023 년의 사건과, 이후 교육·거버넌스·AI Safety 체계 강화, 2026 년 ChatGPT Enterprise 와 Codex 의 대규모 관리형 도입까지 이어지는 변화과정을 관찰할 수 있다는 점에서 적합하다. 이 사례를 “모범기업” 또는 “실패기업”으로 평가하는 것이 아니라, 사고와 위험인자가 조직통제의 성숙도 이동으로 어떻게 연결되는지를 분석한다.

4.3.2 자료수집 및 2023-2026 변화 코딩

2023 년 삼성전자 DS 부문 임직원의 ChatGPT 사용 과정에서 설비·코드 관련 정보와 회의내용 입력 사례가 보도되었고 회사는 입력제한 등 긴급 통제를 적용했다 [11]. 이후 삼성전자는 AI 윤리 이행 가이드와 2024 년부터 전 임직원 대상 의무 AI 윤리교육, AI Governance Council, AI Safety 점검과 AI Red Team 운영을 공식적으로 공개하고 있다 [12]. 2026 년 6 월에는 국내 삼성전자 전 임직원과 글로벌 DX 부문 임직원을 대상으로 ChatGPT Enterprise 와 Codex 도입을 발표했으며, 데이터보호·사용자/접근관리·보안통제와 회사 거버넌스 프레임워크 안에서 사용하도록 설명했다 [13].

시기	주요 변화	연구상 해석
2023	생성형 AI 사용 과정에서 민감정보 입력 사례가 알려짐	입력제한·사용통제 강화

시기	주요 변화	연구상 해석
2024	전 임직원 대상 AI 윤리교육 및 거버넌스 강화	교육과 책임체계의 제도화
2025-2026	AI Safety 점검·Red Team 등 안전관리 공개	기술통제와 조직통제의 결합
2026	ChatGPT Enterprise와 Codex의 대규모 도입	관리형 계정·접근관리·데이터보호를 전제로 한 확장

4.3.3 분석틀

- 사고 전: AI 도입 속도와 데이터분류·입력정책·직원교육의 시차가 있었는가?
- 사고 직후: 입력량 제한·도구 제한 등 즉시 통제가 어떤 위험을 줄였는가?
- 중기: 교육·거버넌스·Safety 평가가 누가 무엇을 판단하고 보고하는지를 어떻게 제도화했는가?
- 확장: 관리형 Enterprise 환경이 소비자형 도구 사용과 어떠한 통제차이를 만드는가?
- SME 적용: 대기업형 SOC를 복제하지 못하는 SME가 어떤 최소통제를 우선 채택할 수 있는가?

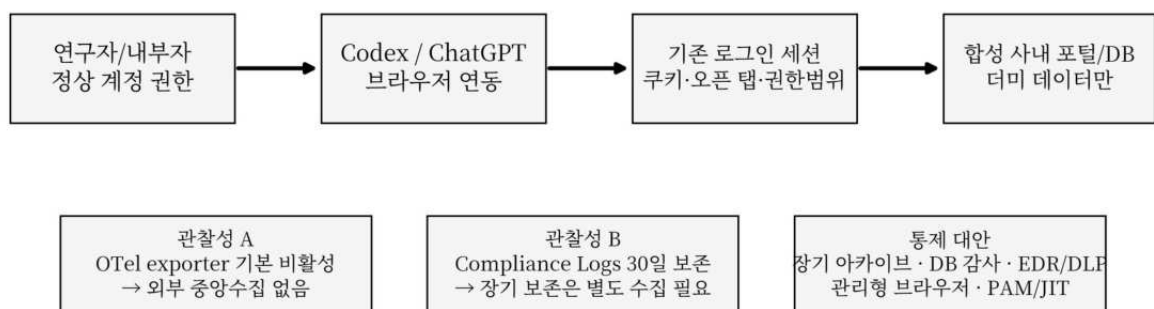
4.4 Study 3 - Codex 합성환경 관찰가능성 실험

4.4.1 실험목적과 예비관찰

본 연구자의 2026년 8월 예비관찰은 실제 기업정보를 사용하지 않고 연구자가 통제하는 테스트 계정과 합성 페이지에서 수행되었다. 관찰의 목적은 보안기능 우회가 아니라, 로그인 세션과 정상권한이 에이전트에 연결될 때 어떤 계층의 증거가 남고 보존조건에 따라 사후 복원가능성이 어떻게 달라지는지를 확인하는 것이다.

Codex 공식 설정 문서에 따르면 OTEL 내보내기는 기본 비활성화이며 exporter의 기본값은 none이다 [14]. Enterprise/Edu Compliance Logs Platform의 기본 보존기간은 30일이고 장기보존을 원할 경우 조직이 로그를 지속적으로 자체 저장해야 한다 [15]. 실험은 이 두 사실을 공격기법이 아니라 “관찰성 설계의 사전조건”으로 취급한다.

Codex 통제 실험의 핵심 관찰 구조 (연구용 합성 환경)



윤리 원칙: 실제 회사·제3자 시스템을 대상으로 하지 않고, 연구자가 소유·통제하는 합성 데이터와 테스트 계정만 사용한다.

그림 4. Codex 관찰가능성 실험의 합성환경 구조. 실제 기업·제3자 시스템을 사용하지 않고 권한 승계, 로그범위, 보존과 ERI의 관계만을 측정한다.

4.4.2 C1-C4 통제조건과 ERI 측정

조건	구성	측정 목적
C1 최소통제	OTel 외부수집 없음, 합성 DB 최소로그	행위 재구성의 사각지대 측정

동일한 정상업무형 합성 시나리오를 각 통제조건에서 반복하고, 독립 조사자가 AI 작업맥락, DB 쿼리 메타데이터, 파일 이벤트, 네트워크 목적지, 인증·세션 귀속성을 얼마나 재구성할 수 있는지를 ERI와 조사시간으로 비교한다. 외부 유출 대신 연구자가 통제하는 수신지로의 허용된 테스트 전송만 사용한다.

4.5 Study 4 - 한국·불가리아 SME 인터뷰 및 설문

핵심형 연구는 한국과 불가리아에서 총 12-20 명의 중소기업 관리자, IT/보안, HR/교육, 국제사업 실무자 인터뷰를 목표로 하되, 국가별 최소 6-8 명을 확보하는 것을 원칙으로 하고 직무군을 가능한 범위에서 균형 있게 포함한다. 접근성이 확보되면 80-150 명 수준의 설문을 추가해 SASMM-4 자가진단, AI 사용정도, 사건경험, 교육방식, 로그보존, 신고문화의 관계를 탐색한다. 표본이 충분하지 않을 경우 통계적 일반화보다 사례 간 메커니즘 설명을 우선한다.

4.5.1 국가 간 비교방법

양국을 성과순으로 비교하지 않고, 동일한 7개 통제영역과 4단계 성숙도 기준을 적용한 뒤 제도환경, 디지털 성숙도, 보안지원체계, 기업규모가 구현방식에 미치는 차이를 cross-case matrix로 비교한다.

4.6 Study 5 - AI 보안교육 파일럿

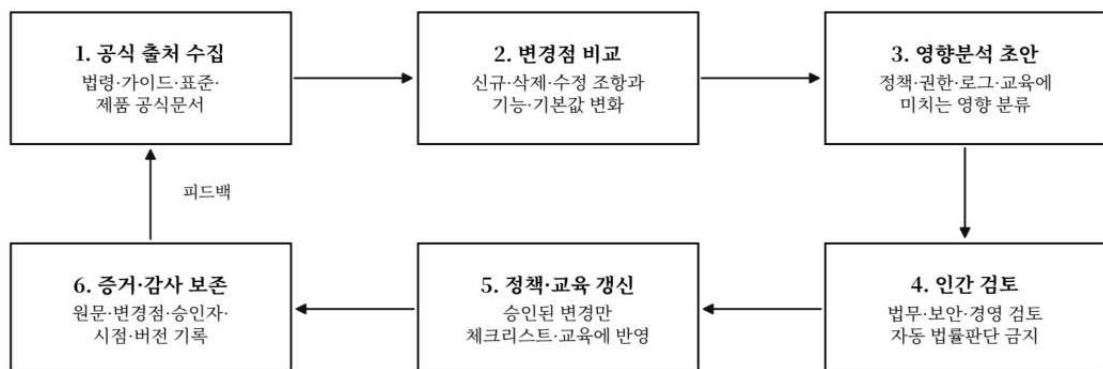
참가자를 텍스트 규정교육군과 “시각적 보안전개도 + 짧은 마이크로러닝”군으로 나누어 즉시·7일·30일 후 위험단계 식별, 금지정보 분류, 올바른 보고시점, 자신감, 기억지속을 비교한다. 교육의 성과는 수료 여부가 아니라 VSR과 시나리오형 판단정확도로 측정한다.

4.7 Study 6 - A-REG 프로토타입

4.7.1 목적과 구조

A-REG(Adaptive Regulation & Governance Loop)는 법령·공식가이드·AI 제품문서의 변경을 자동으로 수집·비교하고, 변경이 내부정책·권한·로그·교육자료에 미칠 가능성이 있는 영향을 초안으로 제시한 뒤 사람의 검토와 승인으로 반영하는 연구용 프로토타입이다. 구현은 prompt-assisted low-code prototyping을 활용할 수 있지만, 핵심 연구대상은 코드의 완성도가 아니라 정책변경 탐지와 통제반영 지연(PCCL), 출처추적성 및 인간 승인 절차의 유지 여부이다.

적응형 규제·보안정책 갱신 프로세스(A-REG)



사고·감사·새 기능 발견 시 출처 목록과 위험모형을 재검토

정책 변경-통제 반영 지연(PCCL): 공식 변경 공표 시점부터 내부 정책·통제·교육 반영 완료까지 걸린 시간

그림 5. A-REG의 적응형 정책 갱신 절차. 변경점 탐지와 영향분류는 자동화할 수 있지만 법적 해석과 정책 발효는 인간 승인을 전제로 한다.

4.7.2 공식 출처 모니터링

구분	공식 출처 예시	감시 대상
한국 법·정책	국가법령정보센터, PIPC, KISA, 과기정통부	법령·가이드·보안 권고 변화
EU/불가리아	EUR-Lex, EU AI Office, Digital Strategy, ENISA	AI Act, AI literacy, 사이버보안, SME 지원정책
국제 프레임워크	NIST AI RMF/CSF, OECD SME AI	성숙도 지표·통제 기준·비교벤치마크
제품 공식문서	승인된 AI 공급자의 보안·권한·로그·브라우저 문서	기본값·권한범위·보존/감사기능 변경

4.7.3 변경점 탐지, 영향매핑, Human Approval

- 비공식 블로그 요약보다 공식 원문·버전·날짜를 우선하고 변경이력을 보존한다.
- AI는 위반 여부, 징계, 신고의무를 최종 판정하지 않는다.
- 변경이 “AI 사용정책”, “관리자 점검표”, “직원 교육자료”, “로그·권한 설정” 중 어디에 영향을 줄 수 있는지 초안을 제시한다.
- 법무·보안·경영의 승인 후에만 정책을 발효하고 승인자·시점·버전을 기록한다.
- 민감한 사내 정책 원문은 공개형 AI에 그대로 입력하지 않고 필요한 경우 비식별·분리된 환경에서 처리한다.

4.7.4 PCCL 측정

공식 변경 공표시점부터 내부 정책·통제·교육 반영 완료시점까지의 시간을 PCCL로 기록한다. 과거 변경사례 10-20건을 이용해 수동 모니터링과 A-REG 보조 프로세스의 발견시간, 분류정확도, false positive/negative, 승인부담, 출처 추적성을 비교한다.

4.8 전문가 검증

정보보안, 개인정보·법무, AI 거버넌스, SME 경영·교육 분야 전문가 8-12명을 대상으로 2라운드 Delphi 또는 구조화 검토를 실시한다. 성숙도 단계, Mandatory Gate, 영역 가중치, 로그보존 목표치, 교육항목, A-REG 절차의 적합성과 현실성을 검증하고 합의가 낮은 항목은 강제기준이 아니라 상황별 옵션으로 분류한다.

4.9 연구윤리 및 데이터관리

- 합성환경 실험은 연구자가 소유·통제하는 더미 DB, 테스트 계정, 테스트 수신지만 사용한다.
- 실제 기업의 기밀 DB·로그인세션·민감정보·제3자 자산은 실험대상에서 제외한다.
- 인터뷰 기업명과 개인은 원칙적으로 익명화하고 실제 보안구성·취약점은 재식별되지 않도록 추상화한다.
- A-REG는 법률자문을 자동화하지 않으며 모든 규제 해석과 정책 발효에는 권한 있는 인간의 검토가 필요하다.
- 로그 장기보존은 개인정보 최소화·목적제한과 함께 설계하고 원문콘텐츠보다 보안 메타데이터 중심으로 검토한다.
- AI 제품기능과 정책은 변할 수 있으므로 기준일과 버전을 기록하고 특정 제품의 현재 기본값을 보편적 사실로 일반화하지 않는다.

4.10 연구 수행가능성·범위통제·추진일정

4.10.1 연구 수행가능성과 기존 연구방향의 연속성

지원자의 기존 연구축은 AI 에이전트 기반 정보역량, 중소기업 국제화, 한국·불가리아 비교에 있다. 정보검색·데이터베이스·디지털 정보환경 학습, SQL·정보처리·Linux·네트워크 기초, 기업교육 프로그램 운영, 영어 통번역과 다문화 경험

은 본 연구를 “보안공학 기술개발”이 아니라 기업이 AI를 안전하게 도입·교육·감사·통제하는 국제경영·조직거버넌스 연구로 수행할 수 있게 한다. 특히 기업교육 운영 경험은 시각적 보안교육과 행동지표를 연구에 포함시키는 실무적 기반이 된다.

4.10.2 12 개월 추진계획

기간	주요활동	산출물
1-2 개월	문헌·법규·표준 검토, SASMM-4 초안, 연구윤리·합성환경 설계	문헌매트릭스·데이터관리계획
3 개월	삼성 및 공개사례 코딩, 한국·불가리아 제도 비교	사례 타임라인·초기 코드북
4-5 개월	SME 인터뷰 1차, C1-C4 통제실험 파일럿	전사·코딩·ERI 측정표
6 개월	시각전개도·마이크로러닝 설계, 전문가 1차 검토	교육콘텐츠 v1·Delphi 1차
7-8 개월	설문/교육 파일럿, A-REG 프로토타입 개발·평가	VSR 데이터·PCCL 실험
9 개월	전문가 2차 검토, 가중치·게이트 조정	SASMM-4 v2
10 개월	사례 간·국가 간 비교, 통합분석	cross-case matrix
11 개월	논문 초고, 실무 가이드 작성	thesis draft·SME toolkit
12 개월	수정·발표·논문화 준비	최종논문·영문초록·투고안

4.10.3 석사과정 범위 통제

핵심형(Minimum Viable Thesis). SASMM-4 + 삼성 사례 + 한국/불가리아 인터뷰 + 합성환경 Codex 관찰성 실험 + 시각교육 소규모 파일럿을 핵심으로 한다. A-REG는 작동 프로토타입 수준으로 제한한다.

확장형(Publication / PhD Pipeline). 표본확대, 30/60/90일 장기 교육효과, 기업 실제 로그정책 비교, A-REG 다국가·다제품 확장, Agent Identity와 공급망은 후속 논문화·박사연구로 확장한다.

제 5 장 분석결과와 구성 및 검증계획

본 문서는 연구계획서이므로 실제 결과를 선결정하지 않는다. 제 5 장은 향후 논문에서 결과를 어떤 순서와 지표로 보고할지 정의하여, 여러 Study 가 서로 별개의 연구처럼 분절되지 않고 SASMM-4 의 검증이라는 하나의 목적에 수렴하도록 설계한다.

5.1 문헌·규제·표준 매핑

각 공식 프레임워크와 법·가이드에서 요구하거나 권고하는 조직행위를 7 개 SASMM-4 영역에 매핑한다. 공통적으로 반복되는 통제와 SME 에 과도한 통제를 구분하고, Mandatory Gate 의 근거와 누락영역을 제시한다.

5.2 삼성전자 사례분석

2023-2026 공개자료를 시간순으로 코딩하여 위험인지, 즉시차단, 교육, 거버넌스, Safety 평가, 관리형 Enterprise 도입의 변화를 SASMM-4 단계이동으로 해석한다. 결과는 사건의 귀책판단보다 조직학습과 통제성숙도의 변화에 초점을 둔다.

5.3 Codex 관찰가능성 실험

C1-C4 에서 ERI, 조사시간, 사용자마찰을 비교한다. 특히 공급자측 단기보존에만 의존하는 조건과 기업 자체 장기아 카이브를 갖춘 조건 사이에서 사고발견 지연에 따른 증거가용성이 어떻게 달라지는지 제시한다.

5.4 한국·불가리아 SME 비교

양국 인터뷰·설문 결과를 7 개 영역과 4 단계 성숙도에 맞춰 사례 내 분석과 사례 간 분석으로 정리한다. 공통된 SME 제약과 국가별 구현차이를 구분하고, 동일한 통제라도 도입비용·교육지원·법규환경에 따라 우선순위가 달라지는지를 분석한다.

5.5 시각적 보안교육 파일럿

텍스트 교육군과 시각전개도·마이크로러닝군의 즉시·7 일·30 일 위험식별, 금지정보 분류, 올바른 신고시점, 기억유지 차이를 비교한다. 표본이 작을 경우 효과크기와 패턴을 탐색적으로 제시하고 통계적 과대해석을 피한다.

5.6 A-REG 프로토타입 평가

수동 모니터링과 A-REG 보조 방식의 변경발견 시간, 원문추적성, 영향분류 정확도, 승인부담을 비교한다. 핵심은 자동 법률판단의 정확도가 아니라 PCCL 을 줄이면서 인간승인과 감사이력을 유지할 수 있는지 여부이다.

5.7 전문가 검증 및 SASMM-4 최종모형

Study 1-6 의 결과를 통합한 뒤 전문가 검토를 통해 가중치, Mandatory Gate, 로그보존 목표치, 교육항목, 정책적응 절차를 조정한다. 최종모형은 “점수표”가 아니라 기업이 현재 위치와 다음 투자단계를 판단할 수 있는 진단·의사결정 도구로 제시한다.

연구 구성요소	구성·측정	의사결정 의미
SASMM-4 (핵심 모형)	7 개 영역 + 4 단계 + Mandatory Gate	조직의 현재 보안 성숙도와 다음 단계
ERI (운영지표)	증거범위·보존·귀속·무결성·조사효율	사고 후 사실관계 복원가능성
VSR (교육효과 변수)	위험식별·보고시점·지연지역	보안교육의 행동·기억 성과
PCCL (운영지표)	공식 변경 공표 -> 내부 통제반영 완료 시간	정책·기술 변화에 대한 조직 적응속도

제 6 장 종합논의

6.1 정상권한 증폭과 Agentic Insider Risk

본 연구가 검토하는 핵심 메커니즘은 “AI가 새로운 권한을 만든다”가 아니라, 정상권한을 가진 사람의 탐색·반복·집계·가공 능력이 에이전트 자동화에 의해 확대될 수 있다는 점이다. 따라서 내부자 위협관리의 단위를 사용자 계정에서 “사용자-에이전트-세션-데이터 경계”로 확장할 필요가 있는지 논의한다.

6.2 SME AI 보안 성숙도의 핵심 메커니즘

SME에서 보안성숙도는 제품의 수가 아니라 최소필수 통제의 충족, 관찰가능성, 직원행동, 사고대응, 정책적응이 얼마나 연결되어 있는가로 설명할 수 있다. SASMM-4는 이러한 결합을 단계별로 비교할 수 있는 경영진 의사결정 프레임워크로 제안된다.

6.3 관찰가능성과 Evidence Readiness

사고가 늦게 발견되는 조직에서는 공급자 또는 시스템의 기본 보존기간보다 장기적인 기업측 아카이브가 중요한 통제일 수 있다. 다만 무조건 장기보존을 정답으로 두지 않고 데이터 최소화화 목적제한을 함께 고려하며, ERI를 통해 “얼마나 오래”보다 “조사에 필요한 어떤 증거가 충분히 남는가”를 논의한다.

6.4 사람과 교육의 역할

중소기업은 모든 위협을 실시간 기술통제로 차단하기 어렵기 때문에 직원·관리자·임원이 위험단계와 보고시점을 기억하는 것이 중요한 보완통제가 된다. 교육을 규정 전달이 아니라 조직의 감지센서와 사고보고체계의 일부로 해석하고, VSR을 통해 기억과 판단을 평가하는 의미를 논의한다.

6.5 Adaptive Policy Governance의 역할

AI 제품기능과 규제가 빠르게 바뀌는 환경에서는 정책이 한 번 만들어진 뒤 고정되는 것이 아니라 지속적으로 갱신되는 운영체계가 필요하다. A-REG와 PCCL은 “법이 기술을 완전히 앞선다”는 비현실적 가정보다 기술·규범 변화와 내부통제 사이의 시차를 관리하는 방식으로 논의를 전환한다.

6.6 한국-불가리아 비교

6.6.1 공통된 SME 제약

보안 전문인력 부족, 레거시 시스템, 승인되지 않은 AI 사용, 권한자 의존, 교육의 형식화는 양국 SME에서 공통적으로 관찰될 수 있는 비교축이다.

6.6.2 한국 특유의 구현양상

높은 디지털 인프라와 빠른 기업 AI 도입은 통제의 구축속도가 기술도입 속도를 따라가지 못하는 Control Drift를 더 선명하게 관찰할 가능성이 있다.

6.6.3 불가리아 특유의 구현양상과 EU 제도환경

불가리아에서는 SME의 낮은 디지털 집약도와 불균등한 사이버성숙도, EU AI Act와 AI literacy 환경이 “고도화된 도구”보다 최소통제·교육·지원체계의 비용효율성을 검토하는 데 적합한 맥락을 제공한다.

6.7 학술적 의의

- 내부자 위협을 정상권한의 에이전트 증폭(APA)이라는 조직메커니즘과 연결한다.
- AI 위협관리, 사이버보안 성숙도, 교육행동, 국제제도 비교를 SME 맥락에서 통합한다.
- ERI와 PCCL을 통해 관찰가능성과 적응속도를 운영 가능한 연구지표로 구체화한다.
- 기존 연구축 I의 AI-enabled Information Capabilities에 “secure governance”라는 경계조건을 추가한다.

6.8 기업경영 및 실무적 의의

- 중소기업 대표가 현재 단계와 다음 투자항목을 판단할 수 있는 4 단계 진단체계를 제공한다.
- 직원·권한자·관리자·임원이 동일한 위험경로를 공유할 수 있는 1-page Security Map 을 제안한다.
- 공급자측 기본 로그에만 의존하지 않고 기업 자체의 증거보존 전략을 수립하도록 한다.
- AI 를 일괄 금지하기보다 안전한 사용을 가능하게 하는 단계형 가이드라인을 제시한다.

6.9 정책적 의의

중소기업 지원정책은 대기업용 보안솔루션 구매지원만으로 충분하지 않을 수 있다. 정부·산업협회·대학이 Minimum AI Security Controls, 공통 시각교육자료, 저비용 로그보존 템플릿, 공식 정책변경 알림·교육갱신 서비스를 패키지로 제공하는 방안을 검토할 수 있다. 특히 불가리아 기업을 둘러싼 상위 EU 제도환경과 AI literacy 정책은 대학-기업-정부 교육프로그램으로 확장할 수 있는 비교기반을 제공한다.

제 7 장 결론

7.1 연구계획의 요약

본 연구는 AI 에이전트 시대의 중소기업 내부자 위협을 하나의 제품취약점이나 개별 사고로 다루지 않고, 정상권한 증폭 -> 관찰가능성·증거보존 -> 교육·행동 -> 사고대응 -> 규제·제품변경 적응으로 이어지는 조직적 문제로 구성한다. SASMM-4는 이러한 요소를 7개 영역과 4단계 성숙도로 묶고, 삼성전자 사례, Codex 합성환경 실험, 한국·불가리아 SME 현장자료, 교육파일럿, A-REG 평가를 통해 검증한다.

7.2 연구질문에 대한 통합적 답변 구조

Main RQ1은 APA를 정상권한 증폭의 설명 메커니즘으로 사용하고 ERI를 운영지표로 활용하여 “정상권한의 자동화가 위협과 증거준비도를 어떻게 바꾸는가”를 설명한다. Main RQ2는 SASMM-4를 핵심 모형으로 두고, VSR은 교육효과 변수, PCCL은 정책적응 속도의 운영지표로 활용하여 “자원이 제한된 SME가 무엇을 최소선으로 하고 어떻게 단계적으로 확장할 것인가”를 설명한다. Main RQ3는 한국-불가리아 비교를 통해 “동일한 모형이 서로 다른 제도·디지털 환경에서 어떻게 다르게 구현되는가”를 설명한다. 이 구조를 통해 각 사례와 실험은 독립된 연구가 아니라 세 개의 Main RQ에 답하기 위한 검증수단으로 정렬된다.

7.3 연구의 한계

한계	위험	대응
SME 접근성	보안정보 공개를 꺼릴 수 있음	비기밀·익명 인터뷰, 공개문서, 전문가 검토로 보완
표본규모	한국-불가리아 정량 일반화 제한	질적 메커니즘과 파일럿 정량을 우선하고 후속연구 확대
제품 변화	Codex 및 타 AI 기능·로그정책 변경	기준일·버전 기록, 제품불변 조직원칙과 A-REG에 초점
법률해석	연구자가 법률가가 아님	공식 원문 우선, 법률결론 대신 정책적응 프로세스 연구
교육효과	단기 테스트가 실제 행동을 완전히 대변하지 못함	지연측정과 시나리오형 판단문항 병행

7.4 후속 연구

- 교육파일럿을 30/60/90 일 장기 추적으로 확대하고 실제 사고보고 행동과 연결한다.
- A-REG를 다국가·다제품 환경으로 확장하고 공식 변경의 영향매핑 정확도를 검증한다.
- Agent Identity, 공급망 AI 에이전트, 제 3자 플러그인·커넥터 위협을 성숙도 모형에 추가한다.
- 실제 기업의 장기 로그보존과 사고대응 자료를 익명화해 ERI의 외적 타당성을 검증한다.
- SASMM-4를 국제화·디지털전환 성과와 연결하여 안전한 AI 정보역량이 기업성과에 미치는 조건을 분석한다.

7.5 장기 연구방향

장기 연구비전. 연구축 I은 AI 에이전트가 SME 국제화를 가능하게 하는 정보역량을 설명하고, 연구축 II는 그 역량을 지속가능하고 신뢰 가능하게 만드는 보안·거버넌스를 설명한다. 향후 박사과정에서는 두 축을 AI-enabled Information Capabilities under Secure Governance 라는 일관된 연구 프로그램으로 결합하여 SME Internationalization, Digital Transformation, AI Governance & Security 를 연결한다.

7.5.1 예상 산출물 및 부록 구성

산출물/부록	내용
학위논문	SASMM-4 와 한국-불가리아 비교를 중심으로 한 주논문
SME 1-page Security Map	직원·임원 공통 시각자료와 역할별 행동규칙
SASMM-4 자가진단표	Mandatory Gate + 7 개 영역 점수 + 투자우선순위
AI Security Microlearning Kit	10-15 분 교육안, 사례카드, 퀴즈, 리마인드
ERI Measurement Sheet	AI/DB/Endpoint/Network 로그 범위·보존·무결성·귀속성 점검
A-REG Prototype Specification	공식 출처 변경감지 -> 영향초안 -> 인간승인 -> 버전보존
Delphi Questionnaire	성숙도·게이트·가중치·권고항목 검증용 전문가 문항

Appendix A. English Abstract

Title: Insider Threats in the AI Agent Era and an AI Security Maturity Model for SMEs: A Korea-Bulgaria Comparative Study of Layered Controls, Evidence Readiness, and Adaptive Policy Governance

This research develops a second, complementary research stream alongside the applicant's existing work on AI-agent-enabled information capabilities and SME internationalization. It examines how AI agents may amplify the operational capacity of legitimate insiders without necessarily creating new privileges, and how resource-constrained SMEs can respond through layered governance, evidence preservation, security education, and adaptive policy management. The four-level SME Agentic Security Maturity Model (SASMM-4) is the core framework. Agentic Privilege Amplification (APA) is treated as an explanatory mechanism; the Evidence Readiness Index (ERI) and Policy Change-to-Control Latency (PCCL) serve as operational metrics, while Visual Security Recall (VSR) is used as an educational outcome measure. The research uses a multiphase mixed-methods design with an exploratory sequential logic, combining regulatory and standards analysis, a longitudinal Samsung Electronics case, controlled experiments in a synthetic Codex/browser environment, interviews and optional surveys with Korean and Bulgarian SMEs, a visual-security-training pilot, an A-REG policy-monitoring prototype, and expert validation. The conceptual framing draws on dynamic capabilities and institutional theory to connect organizational adaptation with cross-country institutional context. The study is not designed to automate legal judgment or reproduce data-exfiltration methods. Its goal is to reduce the organizational lag between technological change and effective controls while preserving human responsibility and SME feasibility. In the long term, this governance-oriented research stream complements the applicant's international-business research on AI-enabled information capabilities and SME internationalization.

Keywords: AI agents; insider threat; SMEs; AI security maturity; AI literacy; observability; evidence readiness; adaptive governance; Korea; Bulgaria; Codex

참고문헌

- [1] OECD (2026). Empowering SMEs in the age of AI: The 2026 OECD D4SME Survey. OECD SME and Entrepreneurship Papers No. 78. https://www.oecd.org/en/publications/empowering-smes-in-the-age-of-ai_bf5a9816-en.html
- [2] ENISA. SMEs Cybersecurity. <https://www.enisa.europa.eu/topics/awareness-and-cyber-hygiene/smes-cybersecurity>
- [3] European Commission (2026). Bulgaria's 2026 Digital Decade Country Report. <https://digital-strategy.ec.europa.eu/en/factpages/bulgarias-2026-digital-decade-country-report>
- [4] OpenAI (2026). Running Codex safely at OpenAI. <https://openai.com/index/running-codex-safely/>

- [5] OpenAI / ChatGPT Learn (2026). Codex Chrome extension. <https://learn.chatgpt.com/docs/capabilities/chrome-extension>
- [6] Eurostat (2026). Digitalisation in Europe - 2026 edition. <https://ec.europa.eu/eurostat/web/interactive-publications/digitalisation-2026>
- [7] European Commission (2026). AI Literacy - Questions & Answers. <https://digital-strategy.ec.europa.eu/en/faqs/ai-literacy-questions-answers>
- [8] 국가법령정보센터 (2026). 인공지능 발전과 신뢰 기반 조성 등에 관한 기본법. <https://www.law.go.kr/>
- [9] 개인정보보호위원회 (2025). 생성형 인공지능(AI) 개발·활용을 위한 개인정보 처리 안내서. <https://www.pipc.go.kr/>
- [10] 한국인터넷진흥원 (2025). 인공지능(AI) 보안 안내서. <https://www.kisa.or.kr/>
- [11] 이코노미스트코리아 (2023). 삼성전자 ChatGPT 사용 과정의 사내정보 유출 보도. <https://economist.co.kr/article/view/ecn202303300057>
- [12] Samsung Electronics (2026). Implementing our AI Ethics Principles. Mandatory AI ethics training, AI Governance Council, AI Safety diagnostic processes and AI Red Team. https://www.samsung.com/global/sustainability/popup/popup_doc/AYUqlrQ6CusAIx_C/
- [13] OpenAI (2026-06-21). Samsung Electronics brings ChatGPT and Codex to employees. <https://openai.com/index/samsung-electronics-chatgpt-codex-deployment/>
- [14] OpenAI / ChatGPT Learn (2026). Codex Advanced Configuration: Observability and telemetry. <https://learn.chatgpt.com/docs/config-file/config-advanced>
- [15] OpenAI Help Center (2026). OpenAI Compliance Platform for Enterprise and Edu Customers. <https://help.openai.com/en/articles/9261474-openai-compliance-platform-for-enterprise-customers>
- [16] NIST (2024). Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (NIST AI 600-1). <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>
- [17] NIST (2024). The NIST Cybersecurity Framework (CSF) 2.0. <https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20>
- [18] European Union (2024, consolidated 2026). Regulation (EU) 2024/1689 (Artificial Intelligence Act). <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng>
- [19] Teece, D. J. (2007). Explicating dynamic capabilities: The nature and microfoundations of (sustainable) enterprise performance. *Strategic Management Journal*, 28(13), 1319-1350. <https://doi.org/10.1002/smj.640>
- [20] DiMaggio, P. J., & Powell, W. W. (1983). The iron cage revisited: Institutional isomorphism and collective rationality in organizational fields. *American Sociological Review*, 48(2), 147-160. <https://doi.org/10.2307/2095101>